

Contents

Service Architecture — Core Domain Service, Internal Auth, Multi-Region	1
1. The question this note answers	1
2. Vocabulary — the patterns by name	2
3. Current state at eng-labs	3
4. Target (“ideal”) architecture	4
5. “Share the logic” vs. “share the client” — the nuance that matters most	5
6. Security angle — what “private Cloud Run” actually buys you	5
7. Multi-region — why the database is the hard part, not the backend services	7
8. Recap — what was verified vs. assumed, across the whole discussion	9
9. If this were ever acted on — rough order of operations	10

Service Architecture — Core Domain Service, Internal Auth, Multi-Region

- **Date:** 2026-09-03
- **Context:** A Claude Code session walking the real satellite-service architecture of the eng-labs platform (apps/guide-agent, apps/manuscript-reviewer, apps/interview-service around the core apps/api) and generalizing it into reusable architecture principles.
- **Companion notes:** [eng-labs-platform.md](#) — the monorepo/runtime source of truth. [multi-tenancy.md](#) — the auth/authorization concepts this note assumes (three-gate contract, enforcement layers).

The one-line answer: one service (the **Core Domain Service**) should own the database and the authorization rules; every other backend service should be a stateless caller of it, reached from the frontend only through it, and trusted via platform-level identity (Cloud Run IAM + short-lived tokens) — not a static shared secret, and not a second copy of the database logic in another language.

1. The question this note answers

Given a platform with one main backend (apps/api) plus several specialized backend workloads (an LLM agent, a batch PDF job, a real-time audio service), each possibly in a different language:

1. Should each service have its own direct database connection, or should one service own the data and expose it via an API?
2. If multiple languages need “the same” auth/DB logic, do you rewrite that logic per language, or share something else?
3. Does the frontend ever call a specialized backend service directly, or always through the core API?
4. How do you secure calls *between* backend services without assuming they share a network (VPC)?
5. What changes if this has to run in more than one geographic region?

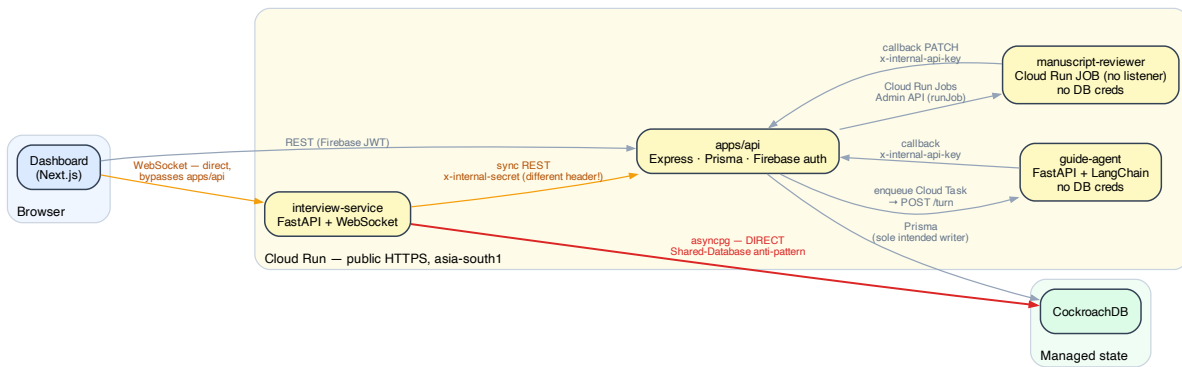
The short answers, in order: **one owner + API, share a generated client, not the logic, always through the core API except a narrow, deliberate exception, platform-level identity (IAM), not network adjacency, replicate the whole stack per region and let the database — not the backend — carry the multi-region complexity.**

2. Vocabulary — the patterns by name

Term	What it means	Where it shows up here
Core Domain Service (a.k.a. System of Record)	The one service that owns a bounded set of tables and is the only thing allowed to write them. Everyone else reaches that data through its API.	<code>apps/api</code> — owns all 199 Prisma models, including tenant/auth data.
Shared Database (anti-pattern)	Two independently-deployed services both connect straight to the same tables. Named as an anti-pattern because it re-couples services through table shape instead of an explicit, versioned contract.	<code>apps/interview-service</code> connecting to CockroachDB directly via <code>asynccpg</code> — the one deviation found in this codebase.
API Gateway pattern	A single public entry point does authentication/authorization/rate-limiting once, then fans requests out internally. Callers outside the perimeter never see the internal services.	<code>apps/api</code> for <code>guide-agent</code> and <code>manuscript-reviewer</code> today; the target state for <code>interview-service</code> too.
Workload-based decomposition	Split services by <i>resource/latency profile</i> , not by team or by “microservices for their own sake.” A 30s LLM loop, a batch PDF job, and a sub-100ms CRUD call have incompatible autoscaling needs, so they shouldn’t share a deployment.	Why <code>guide-agent</code> (long tool-calling loop), <code>manuscript-reviewer</code> (batch job), and <code>apps/api</code> (CRUD) are three separate Cloud Run resources.
Async Request-Reply (callback) pattern	Caller dispatches work and returns immediately; the worker reports the result back later via its own call, instead of holding the HTTP connection open. Needed because some infra (Cloud Tasks) discards response bodies anyway.	<code>apps/api</code> → <code>guide-agent/manuscript-reviewer:dispatch</code> , then a POST/PATCH callback into <code>apps/api/src/routes/internal/*</code> when done.
Generated client SDK	A thin, typed wrapper around an API contract (OpenAPI/Swagger, or gRPC/protobuf), generated per language, so every caller gets the same behavior “for free” without hand-rewriting logic.	The <i>right</i> way to give a Python service “the same auth/DB logic” as the TypeScript core — generate a Python client from <code>apps/api</code> ’s existing <code>/api-docs</code> OpenAPI spec, don’t reimplement the rules in Python.

Term	What it means	Where it shows up here
Externalized policy / authorization service	Authorization <i>decisions</i> (not raw DB access) live in one callable service (e.g. Open Policy Agent, or a Google-Zanzibar-style relationship graph); every language asks “can user X do Y?” over the network instead of encoding the rule locally.	Not present yet in this codebase — the advanced-tier answer to “how do N languages share one authorization truth” without duplicating rule code.
Cloud Run IAM invoker	A private (<code>--no-allow-unauthenticated</code>) Cloud Run service is only reachable by identities explicitly granted <code>roles/run.invoker</code> . The caller attaches a short-lived, Google-signed OIDC ID token; Cloud Run’s own front door verifies it <i>before</i> your container even starts.	The recommended replacement for today’s static <code>x-internal-api-key</code> / <code>x-internal-secret</code> header comparisons done in application code.
REGIONAL BY ROW	A CockroachDB multi-region feature: individual rows (not whole tables) are pinned to a “home” region, so reads/writes for that row stay region-local instead of crossing the WAN on every query.	The actual hard part of going multi-region — see §6.

3. Current state at eng-labs



△ No VPC, no IAM invoker anywhere — every Cloud Run service is public HTTPS, trust is enforced only by static shared-secret headers compared in app code.

Figure 1: Current satellite-service architecture

What this diagram is saying, plainly:

- **apps/api** is already a correct **Core Domain Service** for two of the three satellites. **guide-agent** and **manuscript-reviewer** hold **zero database credentials** — they get a context snapshot from **apps/api**, do their compute, and report back via a callback. This is the right shape and needed no changes.
- **apps/interview-service** is the deviation: it holds its own **asyncpg** connection and queries CockroachDB directly with hand-written tenant-scoping SQL. This is a live **Shared Database** situation — a second, independently-deployed writer against tables **apps/api** also owns, with its own (separately maintained) copy of the multi-tenant scoping logic.
- Two different internal-auth header names exist (**x-internal-api-key** vs **x-internal-secret**) for what should be one mechanism — an inconsistency, not a deliberate split.
- **No VPC, no Cloud Run IAM invoker configuration exists anywhere** in the deploy pipeline (**infra/cloudbuild.yaml**, **infra/cloudbuild-manuscript-reviewer.yaml**). Every service is a public HTTPS endpoint; **interview-service** is even deployed **--allow-unauthenticated**. The only thing standing between the public internet and these “internal” routes today is a static secret string compared in application code.
- The dashboard’s WebSocket connection to **interview-service** bypasses **apps/api** entirely — the one case where the browser talks straight to a satellite service, for real-time audio latency reasons.

4. Target (“ideal”) architecture

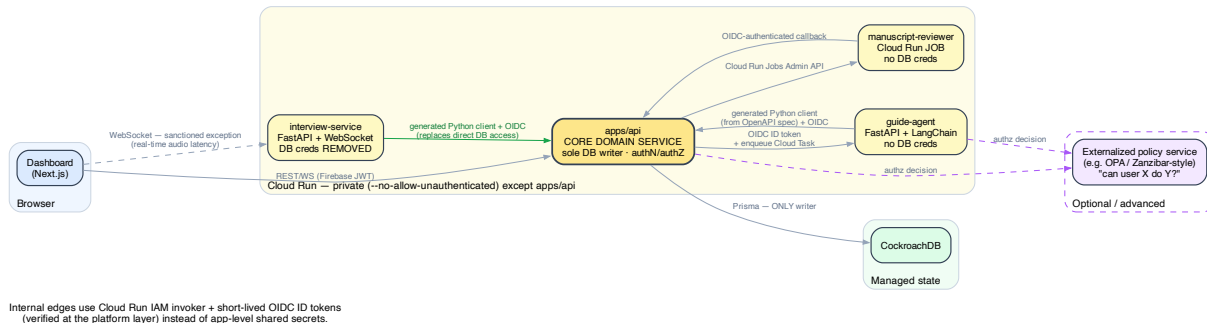


Figure 2: Target architecture

What changes relative to §3:

1. **interview-service gives up its direct DB connection.** It calls **apps/api** (via a generated client, see §5) for whatever tenant/credit data it needs, the same way **guide-agent** already does. This closes the Shared-Database gap and collapses “two copies of the tenant-scoping rule” back down to one.
2. **Every internal call moves from a static shared secret to Cloud Run IAM + OIDC tokens.** Each satellite service is deployed private (**--no-allow-unauthenticated**); only the specific caller identities that need to reach it are granted **roles/run.invoker**, scoped per service — not one blanket secret usable against every internal route at once.
3. **The browser’s WebSocket exception stays — deliberately, not by accident.** It’s the

one workload (live audio) where an extra proxy hop through `apps/api` would cost real, user-perceptible latency. Every other frontend path goes through `apps/api`.

4. **(Optional, advanced)** An externalized policy service is shown dashed because it's not a requirement — only worth adding once “does this rule stay consistent across N languages” becomes a real, recurring pain point, not before.

5. “Share the logic” vs. “share the client” — the nuance that matters most

This was the trap in the original question: “*let’s build the auth/DB logic in both JS and Python.*” That’s the wrong thing to duplicate. Split it into two questions:

What	Should it be shared/duplicated across languages?	How
Business & authorization logic — what counts as a valid tenant scope, which role can do what, how a query gets filtered	No — lives in exactly one place, inside the Core Domain Service, in its native language.	<code>apps/api</code> ’s existing <code>BaseRepository</code> /service-layer pattern.
The client that calls that logic over the network	Yes — generate one per language, don’t hand-write N implementations.	Generate from <code>apps/api</code> ’s existing OpenAPI spec (<code>/api-docs</code>) — e.g. <code>openapi-python-client</code> for Python, or move to gRPC/protobuf if you also want streaming + stronger typing across the board.
Authorization <i>decisions</i>, if truly needed locally in multiple languages	Centralize the <i>decision</i> , not the rule text.	An externalized policy service (OPA / Zanzibar-style) — every language asks a tiny “can X do Y?” question instead of encoding the rule.

Why this matters: two hand-written copies of “filter by `organisation_id/tenant_id`” in two languages **will drift** — one gets patched after an incident, the other doesn’t, and now there’s a tenant-isolation bug that only exists in the language nobody was looking at. A generated client can’t drift from its source spec by construction; at worst it’s stale until regenerated, which is a build-time problem, not a silent runtime security bug.

Does this give independent development? **Yes, on exactly one axis: deployment.** Satellite services can ship on their own schedule without redeploying `apps/api`, as long as the API contract is versioned and stable. It does **not** give independent *data ownership* — they stay coupled to the core’s schema and rules, just through an explicit, generated contract instead of a shared table. That’s the correct tradeoff for a platform where nearly everything needs the same tenant-scoping rule (an edtech SaaS), versus a domain that’s genuinely separable.

6. Security angle — what “private Cloud Run” actually buys you

What it protects against:

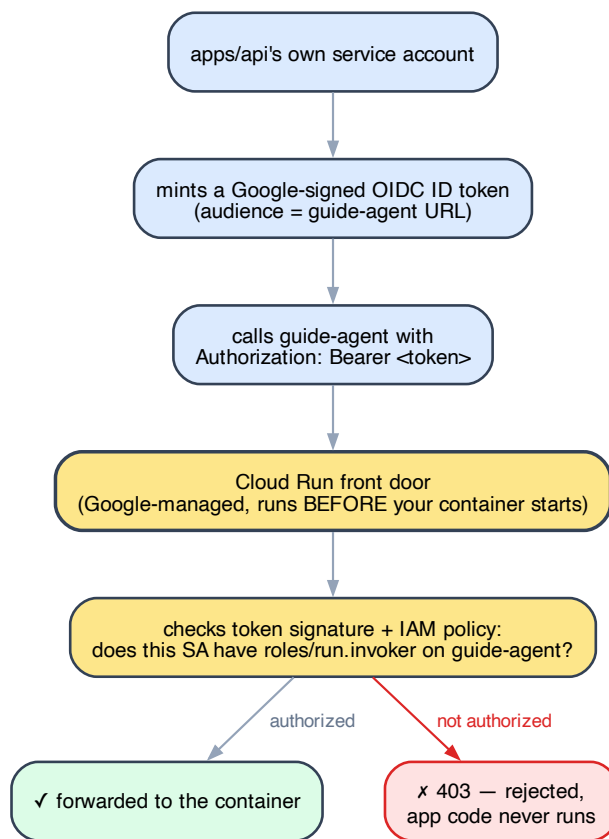


Figure 3: How a private Cloud Run service gets called

- **Anonymous/public access** — a private service (`--no-allow-unauthenticated`) rejects any caller without a valid, IAM-authorized identity, at the platform layer, before your container even boots. Compare: today’s static-secret model relies on every route remembering to check the header correctly — one missed check is an open door.
- **Secret leakage** — there is no long-lived string to leak in logs, source control, or a compromised container’s environment. OIDC tokens are short-lived and minted per-call by the calling service’s own identity.
- **Manual rotation burden** — nothing to rotate; the trust is the IAM binding, not a value.
- **Coarse blast radius** — today, one shared `INTERNAL_API_KEY` value is valid for *every* internal route across every service that checks it. With IAM invoker, each service grants `roles/run.invoker` individually — compromise of one caller’s identity doesn’t automatically grant access to a different service’s internal routes.
- Bonus: every call is now in **Cloud Audit Logs** — “which identity called which private service, when” is a query, not a grep through app logs.

What it does *not* protect against — the things a stakeholder should still ask about even after this migration:

- **SSRF through a still-public endpoint.** If `apps/api` (which stays public, by necessity) has any route that takes a user-supplied URL and fetches it server-side, an attacker can potentially make `apps/api`’s own trusted identity issue requests to private internal services on their behalf. IAM invoker authenticates *who* is calling, not *what* they’re asking a legitimately-authenticated caller to do.
- **Over-broad IAM bindings.** Granting `roles/run.invoker` too widely (e.g. to a whole project instead of one named service account) recreates the “one key unlocks everything” problem in IAM form. Least privilege has to be applied deliberately per binding.
- **What happens *inside* an authorized call.** IAM invoker proves the caller is legitimate; it says nothing about whether that caller’s *payload* is safe (this is exactly why `guide-agent` still needs its own inbound/outbound LLM safety review layer independent of IAM — a different problem, at a different layer).
- **Cross-region requests** aren’t network-isolated to a VPC just because they’re IAM-authenticated — see §7 on why that’s fine for the auth question but not for latency.

Defense in depth, stacked correctly:

1. IAM invoker + OIDC (identity — *who* is calling) — the primary fix here.
2. Per-service least-privilege bindings (blast radius containment).
3. (*Optional hardening layer, not the primary mechanism*) Serverless VPC Access connector / Private Google Access, if you also want to restrict network egress paths, not just identity.
4. Payload-level checks specific to the workload (e.g. `guide-agent`’s LLM reviewers, request validation, rate/budget limits) — orthogonal to all of the above.

7. Multi-region — why the database is the hard part, not the backend services

Two things that were conflated in the original question, worth separating cleanly:

Same-region deployment (already true here — everything sits in `asia-south1`) is about latency. Two Cloud Run services in the same region are physically closer, so round-trips are faster. This is real and worth keeping for any *synchronous* call chain (a user-facing request that blocks on a satellite service’s answer).

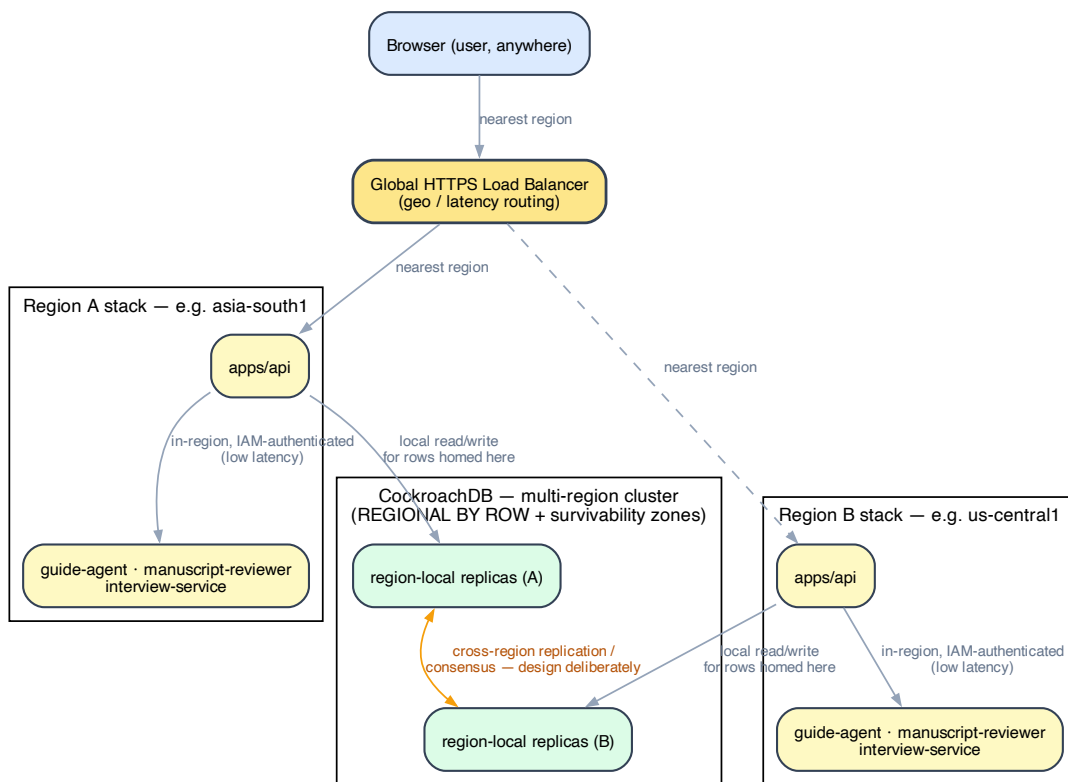


Figure 4: Multi-region deployment

Same-VPC is *not* what makes cross-service calls fast or secure. Cloud Run-to-Cloud-Run traffic already rides Google’s internal backbone even when addressed by public HTTPS URLs — a VPC connector doesn’t meaningfully change that latency. Its actual value is a *second*, *independent* trust boundary (network-level, on top of the identity-level one from §6) — worth adding once IAM invoker is in place, not instead of it.

If this platform ever needs true multi-region (e.g. serving users on two continents):

- **Don’t split one call chain across regions.** Deploying `apps/api` in region A and `guide-agent` in region B just because “they’re separate services” turns every synchronous internal call into a slow, chatty cross-WAN round trip for no benefit. Replicate the *whole* tightly-coupled stack (core + its satellites) per region instead — that’s what the diagram shows.
- **The async-dispatch workloads tolerate cross-region latency fine.** `guide-agent`’s turn dispatch and `manuscript-reviewer`’s job trigger are already `async-with-callback` (§2) — nothing is blocking a live user request during that round trip, so these two could in principle run centrally even if the rest of the stack is regional, if there’s a reason to (e.g. GPU/model availability only in one region). That’s a legitimate exception to “replicate the whole stack,” made deliberately — the same category of exception as the `WebSocket-direct` case in §4.
- **The real bottleneck is CockroachDB, not the backend.** Standing up a second `apps/api` in a new region does nothing for users if every query still has to round-trip to a single-region database. CockroachDB is *designed* for exactly this problem — multi-region survivability zones and **REGIONAL BY ROW** tables, which pin each row to a home region so same-region reads/writes stay local. Going multi-region without configuring this first just relocates the latency bottleneck from “which backend region” to “every DB call,” which is worse, not better.
- **IAM invoker auth (§6) is region-agnostic** — it doesn’t need same-VPC or same-region to work, so it’s not a blocker to any of this; it’s actually a prerequisite, since it’s the mechanism that lets two regional stacks trust each other’s calls without needing to be network-adjacent.
- **Routing:** a global HTTPS load balancer (or DNS-based geo routing) in front, sending each user to their nearest full regional stack.

8. Recap — what was verified vs. assumed, across the whole discussion

Claim examined	Verdict
“Manuscript-reviewer connects to CockroachDB”	Wrong — zero DB access confirmed by reading the code; only <code>interview-service</code> does. (My own diagram was ambiguous and caused the confusion.)
“All services run in the same region”	True — <code>_DEPLOY_REGION: asia-south1</code> in both <code>cloudbuild.yaml</code> and <code>cloudbuild-manuscript-reviewer.yaml</code> .
“All services run in the same VPC”	False — no VPC connector, no private ingress config anywhere; every service is public HTTPS with app-level shared-secret auth.
“One API-layer service should own DB ops; others call it”	Right instinct — this is the standard Core Domain Service pattern, and it’s already true for <code>guide-agent/manuscript-reviewer</code> ; <code>interview-service</code> is the one gap.

Claim examined	Verdict
“Build shared auth/DB logic in both JS and Python”	Right goal, wrong mechanism — share a <i>generated client</i> from one contract, don’t hand-duplicate the <i>rules</i> per language (§5). Also a hard blocker as literally stated: <code>packages/database/packages/helpers</code> are TypeScript-only and cannot be <code>import</code> -ed from Python regardless of design.
“Frontend always calls <code>apps/api</code> , which calls the needed backend service”	Right, with one sanctioned exception — the WebSocket path to <code>interview-service</code> , kept deliberately for real-time audio latency.
“Backend services don’t need to share a VPC with <code>apps/api</code> if same region”	Right conclusion, for the wrong reason as originally framed — the actual enabler isn’t “same region is good enough,” it’s that trust should be IAM/OIDC-based , which works regardless of network adjacency; same-region remains valuable purely for latency, independent of the auth question.
“Keep internal Cloud Run services private, let <code>apps/api</code> call them”	Right — this is exactly Cloud Run IAM invoker. (Minor correction: the deploy flag is <code>--no-allow-unauthenticated</code> , not <code>--allow-no-authenticated</code> .)
“Deploying to another geography, deploy everything there too”	Right instinct — replicate the whole tightly-coupled stack per region; the part that actually needs deliberate design is the database’s multi-region configuration, not the backend services.

9. If this were ever acted on — rough order of operations

Not a commitment, just what the dependency order would look like if the ideal state in §4 were pursued:

1. Fix the internal-auth header inconsistency (`x-internal-api-key` vs `x-internal-secret`) — cheap, no architecture change.
2. Move all internal service-to-service calls from static secrets to Cloud Run IAM invoker + OIDC — unlocks real security gains immediately, independent of anything else here.
3. Generate a Python client from `apps/api`’s OpenAPI spec; migrate `guide-agent`’s existing internal calls to use it (low risk — it already has no DB access, this is a refactor of *how* it calls, not *whether* it’s allowed to).
4. Use that same generated client to remove `interview-service`’s direct `asyncpg`/CockroachDB connection, replacing its tenant-scoping SQL with calls back into `apps/api`.
5. Only then, if cross-language authorization drift becomes a recurring real problem (not preemptively): evaluate an externalized policy service.
6. Multi-region is a much later, separate initiative — gated on a real geographic-latency requirement showing up, and starts with the CockroachDB REGIONAL BY ROW design, not the backend topology.